

บทคัดย่อโครงการ

การรักษาความปลอดภัยในระบบเครือข่ายคอมพิวเตอร์ในปัจจุบันนั้นองค์กรมีความซับซ้อนมากขึ้นเนื่องจากมีผู้ร่วมใช้ระบบมากขึ้นทำให้ความเสี่ยงที่ระบบขององค์กรจะถูกโจมตีมีเพิ่มขึ้นด้วยหากว่าภายในองค์กรมีการใช้เครื่องมือในการรักษาความปลอดภัยเช่นไฟร์วอลล์หรือตัวโปรแกรมตรวจจับพฤติกรรมระบบเครือข่าย ซึ่งการรักษาความปลอดภัยโดยใช้เครื่องมือดังกล่าวยังไม่สามารถให้รายละเอียดของพฤติกรรมของผู้ไม่ประสงค์ดีได้ เนื่องจากว่าเครื่องมือเหล่านั้นใช้เพื่อป้องกันผู้ไม่ประสงค์ดีเข้ามาในระบบเครือข่ายโดยใช้กฎที่ได้กำหนดไว้ก่อน หากการโจมตีนั้นไม่ตรงกับกฎที่กำหนดไว้ก่อนหน้าเครื่องมือนั้นก็ไม่สามารถรักษาความปลอดภัยได้และจะไม่สามารถเก็บข้อมูลการบุกรุกครั้งนั้นได้ ซึ่งแตกต่างกับตัวฮันนีพ็อตที่ใช้หลักการรอรับการโจมตี เฝ้าดูและบันทึกพฤติกรรมการบุกรุก โดยกำหนดเขตของการโจมตีไม่ให้ผู้ไม่ประสงค์ดีเข้าโจมตีระบบจริงได้ เพื่อให้สามารถนำมาวิเคราะห์รูปแบบการโจมตีในแบบต่างๆที่อาจเกิดขึ้นใหม่แม้ไม่ตรงกับกฎที่กำหนดไว้ก่อนหน้าเนื่องจากตัวฮันนีพ็อตใช้หลักการล่อหลอกผู้บุกรุกให้หลงกลเข้ามายังตัวฮันนีพ็อตเพื่อให้เครื่องที่เปิดบริการจริงได้รับความปลอดภัยเพราะผู้บุกรุกได้ตกเข้าไปอยู่กับดักแล้ว

Abstract

In the present network security and host-based security becomes more of an interest and concern for organizations, and most security tools cannot protect and prevent all problems of security of organization. There is no tool which can learn behaviors of hackers, so Honeypot was introduced to solve these problems. Honeypot ,a new generation tool , is a trap set to detect or deflect attempts at unauthorized use of information systems. Honeypots can protect organizations in one of three ways; prevention, detection, and response.

บทนำ (แนวคิด ความสำคัญ ความเป็นมาของโครงการ)

ในระบบเครือข่ายปัจจุบันมีผู้ไม่ประสงค์ดีและประสงค์อยู่ในระบบเครือข่ายเป็นจำนวนมากในการบริการของระบบต่างๆ ไปหากมีการโจมตีของกลุ่มผู้ไม่ประสงค์ดีแล้วกว่าที่ผู้ดูแลระบบจะทราบได้ว่าการโจมตีก็ล่าช้า และ ไม่สามารถที่จะเรียนรู้พฤติกรรมของผู้โจมตีได้ในทันทีที่ต้องมาอ่านและวิเคราะห์เนื้อหาของระบบการดักจับพฤติกรรม (IDS) และอาจจะไม่ทราบทั้งหมดว่าผู้โจมตีได้ทำอะไรลงไปเพราะเราได้เพียงแค่จับในส่วนของ packet ที่ส่งผ่านเข้า และ ออกจากระบบเท่านั้น ทั้งนี้ไม่มีผู้ดูแลระบบคนไหนที่ต้องการเรียนรู้พฤติกรรมการโจมตีด้วยระบบจริงของตนเองด้วยเหตุผลนี้ดังนั้น ผู้ดูแลระบบจึงต้องมีระบบอันนี้เพื่อ เพื่อให้เป็นแหล่งของการเฝ้าดูพฤติกรรมผู้โจมตี และ แยกแยะได้ระหว่างผู้ประสงค์ดีและผู้โจมตี

ระบบอันนี้เพื่อตนเองนั้นไม่ได้มีเพียงแค่ตัวอันนี้เพื่อตนเองเนื่องจากว่าระบบอันนี้เพื่อตนเองไม่ได้มีความสามารถในการแยกแยะระหว่างผู้ประสงค์ดีกับผู้โจมตีจึงมีหลากหลายวิธีที่ช่วยให้การแยกแยะนั้นมีประสิทธิภาพทั้งในการจัดระบบเครือข่ายเองและการใช้อุปกรณ์อื่นเข้ามาช่วยในการแยกแยะ

ในปัจจุบันการดูแลระบบเครือข่ายมีความยากมากขึ้นเนื่องมาจากว่ามีผู้ร่วมใช้ระบบมากขึ้นและมีความเสี่ยงที่ระบบขององค์กรนั้นๆ มีอัตราเสี่ยงในการถูกเข้าโจมตีมากขึ้น ดังนั้น ระบบอันนี้เพื่อจึงได้เข้ามามีบทบาทในการช่วยลดความเสี่ยงและเพิ่มโอกาสในการศึกษาพฤติกรรมและวิธีการเข้ามาในระบบของเราจากผู้ไม่ประสงค์ดี แต่ระบบเครือข่ายขององค์กรที่มีความซับซ้อนนั้นจะเป็นการยากที่เราจะวางตัวระบบอันนี้เพื่อให้ได้ในตำแหน่งที่ดีที่สุดเนื่องจากว่าเราต้องวิเคราะห์และศึกษาในรายละเอียดของระบบเครือข่ายขององค์กรนั้นๆ ก่อน

หลักการและเหตุผล

การศึกษาพฤติกรรมของผู้โจมตีนั้นเป็นสิ่งสำคัญและประโยชน์อย่างมาก ในการวิเคราะห์จากผลการบันทึกพฤติกรรมเพื่อหาทางป้องกันการโจมตีรูปแบบต่างๆ ที่อาจเกิดขึ้นและสามารถแก้ไขได้ในเวลาต่อมา ดังนั้นตัวฮันนี่พ็อตจึงมีความสำคัญและเข้ามามีบทบาทในการเฝ้าดูและบันทึกพฤติกรรมการบุกรุก

วัตถุประสงค์

- เพื่อศึกษาวิธีการจำแนกผู้บุกรุกจากผู้ใช้งานปกติแล้วบันทึกพฤติกรรม
- เพื่อสร้างโปรแกรมต้นแบบสำหรับจำแนกและบันทึกพฤติกรรมผู้บุกรุก

ขอบเขตของโครงการ

- ศึกษาการจัดตั้งระบบฮันนี่พ็อตที่เหมาะสมในระบบเครือข่าย
- ศึกษาวิธีการจำแนกผู้บุกรุกจากผู้ใช้งานปกติแล้วบันทึกพฤติกรรม
- เพื่อสร้างโปรแกรมต้นแบบสำหรับจำแนกและบันทึกพฤติกรรม

ส่วนต่างๆ ของระบบจำแนกและบันทึกพฤติกรรมผู้บุกรุก

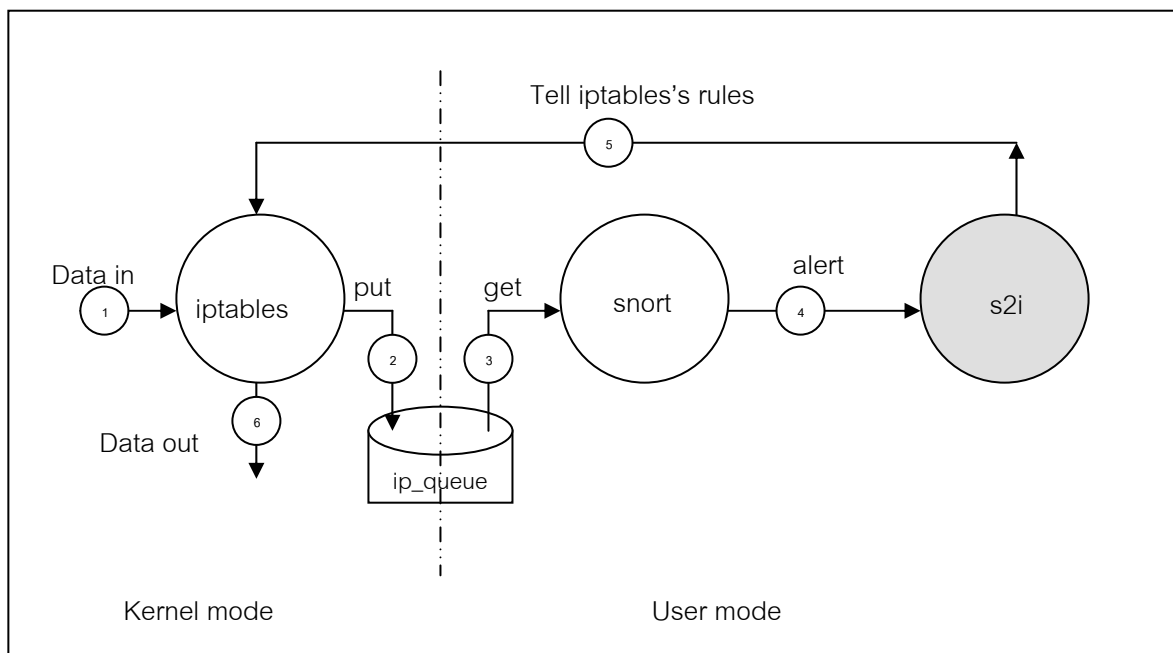
- ส่วนการจำแนกผู้บุกรุกจากผู้ใช้งานระบบ
- ส่วนการควบคุมขอบเขตพฤติกรรมของผู้บุกรุก
- ส่วนการเก็บบันทึกพฤติกรรมและรายงานผล

1. ส่วนการจำแนกผู้บุกรุกจากผู้ใช้งานระบบ

Honeywall

เป็นส่วนที่รับผิดชอบในการจำแนกแยกแยะผู้ที่เข้ามาติดต่อกับระบบเครือข่ายว่าเป็นผู้ใช้งานทั่วไปหรือผู้บุกรุก ส่วนของฮันนี่วอลล์มีโปรแกรมที่เกี่ยวข้องดังนี้

- iptables
- snort_inline
- s2i
 - addremoveMM
 - configMM



รูปที่ 1 โค้ดแอมการทํางานร่วมกันได้ของไฟร์วอลล์และระบบตรวจจับผู้บุกรุก

Iptables

เป็นโปรแกรมทางฝั่งเคอร์เนลโหมด (Kernel mode) ซึ่งเรียกว่าเป็นไฟร์วอลล์ ใช้เพื่อจัดการกับส่วนการเชื่อมต่อ การอนุญาตให้ขึ้นข้อมูลทางระบบเครือข่ายผ่านเข้าออก ในส่วนการใช้งานเพื่อให้ส่งค่าข้อมูลทางระบบเครือข่ายเข้าไปยังส่วนที่โปรแกรมทางยูสเซอร์โหมด (User mode) สามารถนำข้อมูลเหล่านั้นมาใช้ได้โดยผ่าน โมดูลที่ชื่อว่า ip_queue

Snort

เป็นโปรแกรมทางฝั่งยูสเซอร์โหมด (User mode) ซึ่งเรียกว่าเป็นไอดีเอส ซึ่งเป็นระบบตรวจจับผู้บุกรุก โดยใน ส่วนการใช้งานเพื่ออ่านค่าขึ้นข้อมูลแล้วนำมาทำแพตเทิร์นแมชชีน ว่าเข้าข่ายการโจมตีหรือไม่เพื่อกำหนดตามคำสั่งคอนโทรลดังนี้

- **alert** เป็นการแจ้งเตือนว่าตรงกับกฎที่ได้ตั้งไว้
- **drop** เพื่อตัดสินหยุดการส่งผ่านข้อมูลขึ้นเมื่อตรงกับกฎที่ได้ตั้งไว้
- **pass** เพื่อไม่สนใจในขึ้นข้อมูลเมื่อตรงกับกฎที่ได้ตั้งไว้

s2i

เอสทูไอ (S2I: Snort command to iptables) เป็น โปรแกรมที่สร้างจากภาษาคอมไพเลอร์ เพื่อให้สามารถแปลงการแจ้งเตือนของตัวระบบตรวจจับผู้บุกรุกที่สามารถตรวจเจอผู้บุกรุก ให้แปลงเป็นคำสั่งของไฟร์วอลล์ (ไอพีเทเบิล) ได้อย่างเหมาะสมเพื่อให้ขึ้นข้อมูลที่มาจากผู้ใช้งานปกติไปยังส่วนที่ต้องตามต้องการ และในส่วนของผู้บุกรุกเองนั้นก็ส่งไปยังเครื่องกับดัก

addremoveMM

จะติดต่อกับไฟล์ที่ชื่อว่า `iplists.s` เป็นส่วนการกำหนดค่าโดยการเพิ่ม หรือ ลบ และสามารถดูได้ว่าหมายเลขประจำเครื่องผู้บุกรุกเองนั้น มีหมายเลขอะไรบ้างแล้วที่เข้ามาโจมตีระบบเครือข่ายของเรา และในส่วนการทำงานนี้เองเพื่อลดการส่งคำสั่งลงไปยังไฟร์วอลล์ เพื่อลดรันไทม์ (run time) ของระบบให้ประหยัดทรัพยากรณ์ในระบบลงได้บ้างและเพื่อตรวจสอบดูว่าผู้ใดที่เข้ามาในระบบบ้างแล้ว

configMM

เป็นส่วนการทำงานเพื่อกำหนดค่าจากไฟล์ที่ชื่อว่า `s2i.conf` เป็นส่วนการกำหนดค่า ของหมายเลขประจำเครื่องกับดัก และส่วนการบอกชื่ออินเทอร์เน็ตเฟส การเชื่อมต่อของตัวฮันนีวอลล์ ว่ามีการส่งขึ้นข้อมูลเข้าออกด้วยชื่ออินเทอร์เน็ตเฟสใดบ้าง และการกำหนดหมายเลขประจำเครื่องได้นั้นเพื่ออำนวยความสะดวกในการกำหนดกับดักหลายกับดักและหลายหมายเลขได้ โดยกำหนดผ่านทางไฟล์ ดังกล่าว

2. ส่วนการควบคุมขอบเขตพฤติกรรมของผู้บุกรุก

Cage

เป็นส่วนของกับดักเพื่อเป็นที่ใช้เพื่อปล่อยให้ผู้บุกรุกเข้ามาติดกับและดูพฤติกรรมของผู้บุกรุกที่อยู่ในกับดัก

- `sebek_client`
- `Isaghoneypot`
- `portsentry`

sebek_client

เรียกว่า เซเบค ไคลเอน จะซ่อนตัวอยู่ในกับดักเพื่อรอดูพฤติกรรมของผู้บุกรุก และคอยส่งข้อมูลนั้นไปยังเครื่องที่ใช้เก็บพฤติกรรมลงฐานข้อมูล โดยผ่านช่องทางที่มีความปลอดภัย มีการเข้ารหัสในรูปแบบของ เซเบคเอง และใช้การส่งเป็นแบบยูคิพี

isaghoneypot

เป็น service ที่คอยตรวจสอบสิ่งที่อยู่ใน cage และจะทำการ pause ตัว cage ไว้หากมีความอ่อนแอเกินกว่าที่ได้กำหนดไว้

การตรวจสอบจะทำโดยเก็บค่าเริ่มต้นจาก cage เช่น,จำนวนชื่อผู้ใช้ระบบ,ค่า hash ของ password root หลังจากนั้นจะทำการตรวจสอบโดยตรวจสอบข้อมูลดังกล่าวผ่านทางโปรโตคอล SSH

portsentry

เพื่อรองรับการร้องขอการเชื่อมต่อที่อาจเกิดขึ้นจากผู้บุกรุกที่เข้ามายังระบบจริงที่ไม่มีการเปิดให้บริการนั้นอยู่ ให้สามารถจำลองและหลอกให้ผู้บุกรุกโจมตี จากนั้น Honeypot ก็จะบันทึกการกระทำของผู้บุกรุกไว้

3. ส่วนการเก็บบันทึกพฤติกรรมและรายงานผล

Logserver

เป็นส่วนที่ใช้เพื่อเก็บข้อมูลการเฝ้าดูพฤติกรรมจากเครื่องกับดักที่ตัวเซเบคไคล์เอน เป็นผู้ส่งมา

- Web server set
 - Apache
 - Php
 - Mysql
- sebek_server
- sebek_web

Web server set

เพื่อทำหน้าที่ในการอำนวยความสะดวกในการเข้าสู่ข้อมูลที่สามารถจัดเก็บได้จากเครื่องกับดัก และช่วยในการจัดการฐานข้อมูล

sebek_server

เซเบค เซิร์ฟเวอร์ จะทำหน้าที่รับฟังเพื่อรับค่าข้อมูลที่เซเบค ไคล์เอนดักจับข้อมูลจากกับดัก และระบบการทำงานจะส่งค่าไปเก็บยังฐานข้อมูลที่ได้เตรียมไว้

sebek_web

เพื่อเป็นส่วนการแสดงผลข้อมูลที่สามารถจัดเก็บได้จากผู้บุกรุกที่ตกไปอยู่ในกับดักเพื่ออำนวยความสะดวกในการตรวจสอบจากผู้ดูแลระบบ

แนวคิดของระบบจำแนกและบันทึกพฤติกรรมผู้บุกรุกกับระบบรักษาความปลอดภัยอื่น

ระบบอันนี้เพื่อแสดงให้เห็นหลักการรักษาความปลอดภัยระบบเครือข่ายโดยวิธีการล่อลวงให้ผู้บุกรุกเข้าไปสู่เครื่องกับดัก ซึ่งแนวคิดนี้เพื่อเป็นประโยชน์ในการศึกษาว่าผู้บุกรุกได้ใช้วิธีการอย่างไรในการเข้ามาในระบบ ซึ่งเมื่อเทียบกับแนวคิดของเครื่องมืออื่นๆ นั้นจะมุ่งเน้นป้องกันไม่ให้เกิดการบุกรุกนั้นเข้ามาในระบบเครือข่ายได้ เพื่อไม่ให้เกิดความเสียหายแก่ระบบที่ต้องการให้ปลอดภัย เครื่องมือดังกล่าวเช่น ไฟร์วอลล์, ระบบตรวจจับผู้บุกรุก

หลักการในการจำแนกและบันทึกพฤติกรรมผู้บุกรุก

ในการทำงานของส่วนการจำแนกและคัดแยก ระหว่างผู้ใช้งานทั่วไปกับผู้บุกรุกนั้นเป็นส่วนการทำงานของตัวเกตเวย์ เรียกกันว่าฮันนีวอลล์ (Honeywall) ซึ่งเป็นส่วนที่ใช้เพื่อเป็นทางผ่านของข้อมูลทุกชิ้นที่จะเข้ามาในระบบเครือข่าย ในลักษณะการติดตั้งตัวเกตเวย์ไว้ที่ส่วนที่เสมือนประตูทางเข้าออกนี้ เป็นส่วนที่สามารถใช้ประโยชน์ของระบบตรวจจับผู้บุกรุก (snort) เข้าไปเพื่อให้การวิเคราะห์และจำแนกผู้บุกรุกนั้นมีประสิทธิภาพสูงสุด แต่ในส่วนการทำงานเพียงลำพังของระบบตรวจจับผู้บุกรุก นั้นไม่เพียงพอที่จะจัดการให้ผู้บุกรุกเข้าสู่ระบบกับดักที่จัดเตรียมไว้ได้ เนื่องจากระบบตรวจจับผู้บุกรุกนั้นไม่มีความสามารถเพียงพอในการจัดการด้านช่องทางการเชื่อมต่อ ซึ่งความสามารถนี้เป็นความสามารถของไฟร์วอลล์ ที่มีชื่อเรียกว่า ไอพีเทเบิล เพื่อเป็นตัวที่เพิ่มขึ้นมาเพื่อเป็นตัวจัดการ การเชื่อมต่อสื่อสารเพื่อให้เป็นไปตามความต้องการของผู้พัฒนา แต่ในการทำงานจริงนั้น ทั้งสองโปรแกรมนี้ไม่สามารถพูดคุยเพื่อควบคุมกันได้ เพราะความสามารถที่มีนั้นเป็นแค่เพียง ไฟร์วอลล์นั้นส่งค่าของชิ้นข้อมูลไปยังส่วนที่โปรแกรมในส่วนยูเซอร์โหมด (user mode) ก็คือตัวระบบตรวจจับผู้บุกรุก (snort) เนื่องจากว่าไฟร์วอลล์เองเป็นโปรแกรมที่ทำงานในส่วนของเคอร์เนลโหมด (kernel mode) ดังนั้นทางผู้พัฒนาจึงได้คิดแนวทางใหม่ออกมาได้ว่า หากความสามารถของทั้งสองโปรแกรมนี้สามารถเชื่อมต่อกันได้ จะทำให้ประสิทธิภาพการทำงานของระบบจำแนกแยกแยะผู้บุกรุกนั้น มีประสิทธิภาพที่ดีมากกว่าที่เป็นอยู่ ด้วยเหตุนี้เองผู้พัฒนาจึงได้คิดหาแนวทาง โดยการสร้างโปรแกรมที่ใช้เป็นตัวกลาง เพื่อสื่อสารระหว่างระบบตรวจจับผู้บุกรุกกับไฟร์วอลล์เป็นตัวที่ใช้การอ่านค่าจากการแจ้งเตือนจากระบบตรวจจับผู้บุกรุก และอ่านค่าที่ได้มานั้นแปลงเป็นคำสั่งของไอพีเทเบิล อย่างเหมาะสมเพื่อสั่งให้จัดส่งชิ้นข้อมูลไปยังปลายทางที่ถูกต้อง ที่กล่าวมานี้เป็นแนวทางในการสร้างส่วนจำแนกแยะผู้บุกรุกกับผู้ใช้งานทั่วไป

การทำงาน

ในส่วนการทำงานของระบบฮันนีวอลล์นั้น จะอ่านข้อมูลที่ผ่านเข้าออกตลอดเวลา ในส่วนการติดต่อเข้ามาในระบบเครือข่ายนั้นจะพิจารณาว่าชิ้นข้อมูลที่กำลังผ่านเข้ามานั้น ควรจะถูกส่งไปยังที่ใดในระบบเครือข่าย ผู้ใช้ที่พิจารณามีเพียงสองประเภท ดังนี้

ผู้ใช้งานทั่วไป เป็นผู้ที่ติดต่อยังระบบเครือข่ายที่มีรูปแบบการติดต่อเข้ามาอย่างปกติ โดยไม่มีรูปแบบการส่งชิ้นข้อมูลที่น่าสงสัย หรือกระทำพฤติกรรมที่น่าสงสัย ดังนั้นตัวฮันนีวอลล์เองจะส่งชิ้นข้อมูลที่ติดต่อเข้ามาไปยังเครื่องปลายทางที่ผู้ใช้งานปกติต้องการ โดยจะกล่าววิธีจำแนกในหัวข้อต่อไป

ผู้บุกรุกหรือผู้ที่มีพฤติกรรมน่าสงสัย เป็นส่วนการติดต่อมายังระบบเครือข่ายที่มีรูปแบบการติดต่อที่น่าสงสัยเข้าข่ายการโจมตี เมื่อผู้บุกรุกต้องการโจมตีไปยังเครื่องที่ให้บริการจริง ระบบในส่วนของมันนี่เองจะตรวจสอบได้ว่าเป็นผู้บุกรุก จึงจัดการส่งให้การเชื่อมต่อนั้นเปลี่ยนแปลงให้ไปติดต่อในส่วนของก๊อบดัก แต่การเชื่อมต่อนี้ผู้บุกรุกเอง เมื่อตรวจสอบการเชื่อมต่อที่เครื่องของผู้บุกรุกเอง จะพบว่าได้ติดต่อไปยังเครื่องให้บริการจริง ในส่วนการสร้างนี้ยังไม่รวมความรับผิดชอบในเรื่องของความแม่นยำในก๊อบดัก เช่นเมื่อใช้คำสั่งที่แสดงตัวตนของเครื่องที่ได้เชื่อมต่อไป ก็จะพบว่าไม่ใช่เครื่องที่ให้บริการจริง แต่จะได้รับการพัฒนาในปีต่อไป

วิธีจำแนก

จำแนกว่าเป็นผู้บุกรุก

ในการจำแนกผู้บุกรุกนั้นผู้พัฒนาได้ปรับเปลี่ยนกฎของระบบตรวจจับผู้บุกรุก (snort) เพื่อให้มีความสามารถในการพิจารณาและแยกแยะได้ว่าการเชื่อมต่อเข้ามาเช่นไรที่เป็นรูปแบบของการบุกรุก

การจำแนกว่าเป็นผู้ใช้ปกติ

ในส่วนการควบคุมหากว่าไม่ต้องการให้ตรวจสอบเครื่องบางหมายเลขจะต้องกำหนดกฎการอนุญาตให้เข้าได้โดยไม่ตรวจสอบได้โดยการกำหนดกฎที่ ไฟร์วอลล์ เนื่องจากว่าผู้ที่ควบคุมการเชื่อมต่อจริงแล้วคือ ไฟร์วอลล์ และในส่วนของระบบตรวจจับผู้บุกรุกนั้น หากว่าจะกำหนดให้ผู้ใช้งานปกติสามารถเข้ามาได้อย่างไม่มีปัญหาในการตรวจสอบผิดพลาดจำเป็นต้องตั้งกฎของระบบตรวจจับผู้บุกรุก ให้มีความรัดกุมและบ่งบอกชัดเจนว่าผู้ใดเป็นผู้บุกรุก เพื่อให้กระบวนการตรวจสอบนั้นไม่เกิดผลการเข้าใจผิดว่า ผู้ใช้งานปกติเป็นผู้บุกรุก ดังนั้นควรที่จะใช้กฎของระบบตรวจจับผู้บุกรุกที่ได้มาจากของเดิมโดยไม่แก้ไขใดๆ หรือแก้ไขเพียงบางส่วนแต่ยังคงพฤติกรรมที่ชัดเจนในการแสดงว่าเป็นผู้บุกรุก ผู้ใช้ปกติในระบบนี้จะถือว่า เมื่อไม่ตรงกับการตรวจสอบจากระบบตรวจจับผู้บุกรุก ให้ถือว่าเป็นผู้ใช้งานปกติทั้งหมด และไม่ควรตั้งให้ตัวกฎของระบบตรวจจับผู้บุกรุกนั้นส่งผ่านข้อมูลโดยไม่สนใจผ่านคำสั่งพาสส์ (pass) ซึ่งผู้บุกรุกเองอาจจะใช้ช่องทางนี้เพื่อทำการหลีกเลี่ยงการตรวจสอบได้

วิธีการล่อหลอก และ ดักเฝ้าดูพฤติกรรมผู้บุกรุก

ในส่วนการล่อหลอกผู้บุกรุกนั้นระบบอันนี้เพื่อตที่ใช้ทฤษฎีดั้งเดิม (Original concept) นั้นจะใช้การเปิดเครื่องที่อ่อนแอที่สุดในระบบเพื่อใช้ให้เป็นเครื่องก๊อบดัก จากนั้นรอให้ผู้บุกรุกสนใจและเข้ามาในก๊อบดักเอง ในก๊อบดักนั้นได้มีการติดตั้งเครื่องมือ ที่ใช้ดักจับเฝ้าดูพฤติกรรม แต่หากว่าผู้บุกรุกเองไม่ได้เข้ายังเครื่องก๊อบดักด้วยเหตุที่ว่าทราบหมายเลขประจำเครื่องของเครื่องให้บริการจริงแล้วหรือไม่สนใจเครื่องก๊อบดักก็ตามระบบอันนี้เพื่อตตามทฤษฎีเดิมก็จะหมดความหมายไปในทันที แต่ในส่วนของมันนี้เพื่อตตามทฤษฎีที่กลุ่มผู้พัฒนาได้คิดนั้นจะไม่รอให้ผู้บุกรุกสนใจกับตัวก๊อบดักเอง แต่ได้ออกแบบให้มีการบังคับให้ผู้บุกรุกเข้ามายังเครื่องก๊อบดักเองโดยไม่ทันได้รู้ตัวว่าได้เข้ามายังเครื่องก๊อบดักแล้ว ดังนั้นจะยังก็ทำตามระบบอันนี้เพื่อตเองก็ยังคงใช้ได้ซึ่งประโยชน์ตามวัตถุประสงค์ และที่ตัวก๊อบดักเองก็ได้ติดตั้งระบบจับเก็บพฤติกรรม ผู้บุกรุกที่อยู่ในระบบได้ และ

ส่วนที่ได้เพิ่มขึ้นมาคือ เมื่อกับดักเองบอบซ้ำเกินกว่าที่ผู้ดูแลเห็นสมควร ระบบจะมีรูปแบบการป้องกันกับดัก ซึ่งจะได้อธิบายในบทถัดไป

เครื่องมือจากทฤษฎีตั้งต้น

เครื่องมือที่มีเพื่อการจัดทำเป็นระบบอันนี้เพื่อต้น มีชื่อเรียกและคุณสมบัติดังนี้

- **iptables** เป็นโปรแกรมทางฝั่งเคอร์เนลโหมด (Kernel mode) ซึ่งเรียกว่าเป็นไฟร์วอลล์ ใช้เพื่อจัดการกับส่วนการเชื่อมต่อ การอนุญาตให้ขึ้นข้อมูลทางระบบเครือข่ายผ่านเข้าออก ในส่วนการใช้งานเพื่อให้ส่งค่าข้อมูลทางระบบเครือข่ายเข้าไปยังส่วนที่โปรแกรมทางยูสเซอร์โหมด (User mode) สามารถนำข้อมูลเหล่านั้นมาใช้ได้โดยผ่านโมดูลที่ชื่อว่า `ip_queue`
- **snort** เป็นโปรแกรมทางฝั่งยูสเซอร์โหมด (User mode) ซึ่งเรียกว่าเป็นไอดีเอส ซึ่งเป็นระบบตรวจจับผู้บุกรุก โดยในส่วนการใช้งานเพื่ออ่านค่าขึ้นข้อมูลแล้วนำมาทำแพตเทิร์นแมชชีน ว่าเข้าข่ายการโจมตีหรือไม่เพื่อกำหนดตามคำสั่งคอนโทรลดังนี้
 - **alert** เป็นการแจ้งเตือนว่าตรงกับกฎที่ได้ตั้งไว้
 - **drop** เพื่อตัดสินหยุดการส่งผ่านข้อมูลขึ้นเมื่อตรงกับกฎที่ได้ตั้งไว้
 - **pass** เพื่อไม่สนใจในขึ้นข้อมูลเมื่อตรงกับกฎที่ได้ตั้งไว้
- **sebek** เป็นโปรแกรมที่ใช้เพื่อรับผิดชอบการดูพฤติกรรมและจัดเก็บพฤติกรรมของผู้บุกรุก เพื่อใช้เป็นแหล่งข้อมูลในการ นำมาวิเคราะห์ว่าผู้บุกรุกได้กระทำการใดบ้างเมื่อเข้ามาติดอยู่ในกับดัก โดยตัวเซเบค เองก็มีส่วนการรับผิดชอบดังนี้
 - **sebek-client** เรียกว่า เซเบค ไคลเอน จะซ่อนตัวอยู่ในกับดักเพื่อรอดูพฤติกรรมของผู้บุกรุก และคอยส่งข้อมูลนั้นไปยังเครื่องที่ใช้เก็บพฤติกรรมลงฐานข้อมูล โดยผ่านช่องทางที่มีความปลอดภัย มีการเข้ารหัสในรูปแบบของ เซเบคเอง และใช้การส่งเป็นแบบยูติพี
 - **sebek-server** เรียกว่า เซเบค เซิร์ฟเวอร์ จะทำหน้าที่รับฟังเพื่อรับค่าข้อมูลที่เซเบค ไคลเอนดักจับข้อมูลจากกับดัก และระบบการทำงานจะส่งค่าไปเก็บยังฐานข้อมูลที่ได้เตรียมไว้

เครื่องมือจากทฤษฎีใหม่

เครื่องมือที่ได้พัฒนาขึ้นมาใหม่นั้นเพื่อใช้เป็นผู้สื่อสารกลางระหว่าง ไฟร์วอลล์ (ไอพีเทเบิล) กับ ระบบตรวจจับผู้บุกรุก (สนอร์ท) เพื่อให้สามารถสื่อสารระหว่างกันได้ และควบคุมขึ้นข้อมูลที่ผ่านเข้าออก จากระบบเครือข่ายได้อย่างมีประสิทธิภาพมาก โปรแกรมที่ได้สร้างขึ้นมีดังนี้

- **s2i** เรียกว่า เอสทูไอ (**S2I: Snort command to iptables**) เป็นโปรแกรมที่สร้างจากภาษาคอมไพเลอร์ เพื่อให้สามารถแปลงการแจ้งเตือนของตัวระบบตรวจจับผู้บุกรุกที่สามารถตรวจเจอผู้บุกรุก ให้แปลงเป็นคำสั่งของไฟร์วอลล์ (ไอพีเทเบิล) ได้อย่างเหมาะสมเพื่อให้ขึ้นข้อมูลที่มาจากผู้ใช้งานปกติไปยังส่วนที่ถูกต้องตามต้องการ และ

ในส่วนของผู้บูทกรเองนั้นก็ส่งไปยังเครื่องกับดัก ตัวเอสทูไอสามารถกำหนดเปลี่ยนแปลงค่า ต่างๆ ได้เพื่อให้เกิดความเหมาะสมในการใช้งานกับระบบเครือข่ายอื่นๆ ซึ่งมีโปรแกรมเสริมดังนี้

- O **configMM** เป็นส่วนการทำงานเพื่อกำหนดค่าจากไฟล์ที่ชื่อว่า s2i.conf เป็นส่วนการกำหนดค่า ของหมายเลขประจำเครื่องกับดัก และส่วนการบอกชื่ออินเทอร์เน็ตเฟส การเชื่อมต่อของตัวฮาร์ดแวร์ ว่ามีการส่งขึ้นข้อมูลเข้าออกด้วยชื่ออินเทอร์เน็ตเฟสใดบ้าง และการกำหนดหมายเลขประจำเครื่องได้นั้นเพื่ออำนวยความสะดวกในการกำหนดกับดักหลายกับดักและหลายหมายเลขได้ โดยกำหนดผ่านทางไฟล์ ดังกล่าว
- O **addremoveMM** จะติดต่อกับไฟล์ที่ชื่อว่า iplist.s เป็นส่วนการกำหนดค่าโดยการเพิ่ม หรือ ลบ และสามารถดู ได้ว่าหมายเลขประจำเครื่องผู้บูทกรเองนั้น มีหมายเลขอะไรบ้างแล้วที่เข้ามาโจมตีระบบเครือข่ายของเรา และในส่วนการทำงานนี้เองเพื่อลดการส่งค่าส่งลงไปยังไฟร์วอลล์ เพื่อลดรันไทม์ (run time) ของระบบให้ประหยัดทรัพยากรในระบบลงได้บ้างและเพื่อตรวจสอบว่าผู้ใดที่เข้ามาในระบบบ้างแล้ว

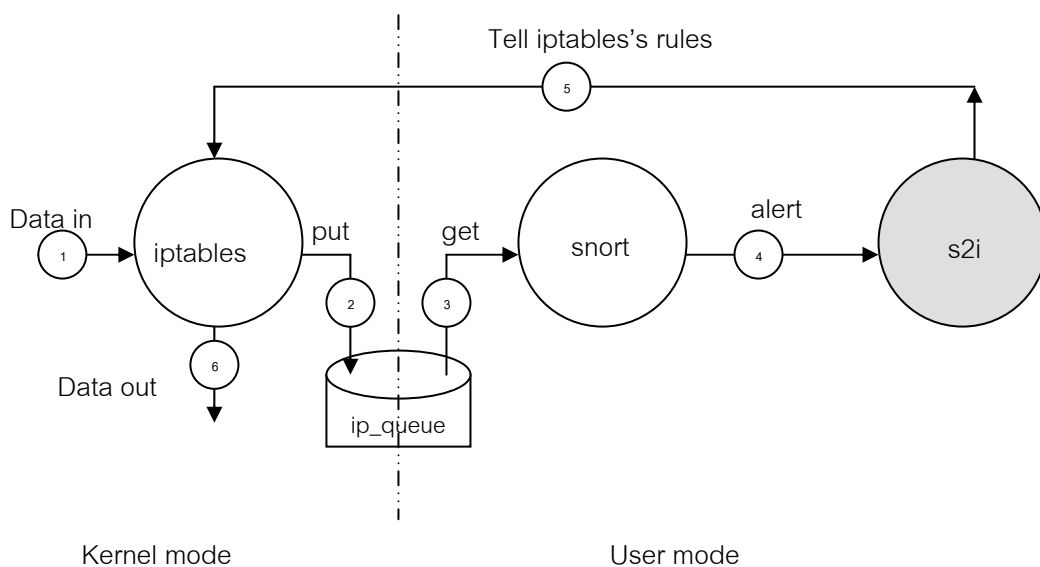
การปรับใช้และแก้ไขเครื่องมือจากทฤษฎีตั้งต้น

จากเครื่องมือดังที่ได้กล่าวมา นั้นเป็นเครื่องมือที่ได้มีการจัดเตรียมไว้ก่อนหน้าที่ผู้พัฒนาจะมาพัฒนาต่อดังนั้นเมื่อของเดิมมีอยู่แล้วและมีประสิทธิภาพ ดังนั้นจึงนำมาประยุกต์ใช้งานในระบบ ดังนี้

- **iptables** ตัวไฟร์วอลล์ (ไอพีเทเบิล) นี้ศึกษาเพิ่มในส่วนของการทำ PREROUTING (DNAT: Destination Network Address Translation) เพื่อทำในส่วนการเปลี่ยนการเชื่อมต่อจากผู้บูทกรไปยังเครื่องกับดักโดยไม่ให้ผู้บูทกรรู้ว่า ติดต่อกับเครื่องที่ไม่ใช่ที่ผู้บูทกรต้องการ ในส่วนการทำ DNAT นั้น ต้องมีการปรับเปลี่ยนเคอร์เนลให้เหมาะสม เพื่อใช้เป็น Bridge (IEEE 802.1d) เพื่อให้สามารถทำตัวเองเป็นเกตเวย์ได้ และใช้ความสามารถของการทำ NAT ได้ ในส่วนการทำงานของ ไฟร์วอลล์อธิบายไว้ในส่วนของบทที่ 4 เรื่องไฟร์วอลล์ ในส่วนของการทำ DNAT นี้ตามทฤษฎีเก่าที่กล่าวมานั้นยังไม่มีมีการคิดค้นเพื่อใช้งาน เพียงแต่ว่าใช้ในส่วนการส่งค่าขึ้นข้อมูลทางระบบเครือข่ายไปยังส่วนที่ทำให้ยูสเซอร์โหมค อ่านค่าได้เท่านั้น แต่ในส่วนการพัฒนาตามทฤษฎีใหม่นี้ ได้ดึงความสามารถของ ไฟร์วอลล์ (ไอพีเทเบิล) มาใช้อย่างเต็มประสิทธิภาพ และให้ผลลัพธ์ที่น่าพอใจอย่างยิ่งคือทางผู้บูทกรเอง เมื่อตรวจสอบการเชื่อมต่อที่เครื่องของผู้บูทกรเองนั้นจะพบว่าได้ติดต่อไปยังเครื่องที่ผู้บูทกรต้องการแต่แท้จริงแล้วได้ตกมาอยู่ในกับดักที่เราได้เตรียมไว้
- **snort** ตัวระบบตรวจจับผู้บูทกรในส่วนของตัวเองโปรแกรมเองทางผู้พัฒนาไม่ได้เข้าไปแก้ไขแต่ประการใด แต่ได้เข้าไปเปลี่ยนแปลงแก้ไขในส่วนของกฎที่ใช้เพื่อทำแพทเทิร์นแมชชีนกับข้อมูลที่อ่านขึ้นมาได้จาก ip_queue
- **sebek** ในส่วนของเซเบคนั้นได้จัดการแก้ไขเนื้อโปรแกรมของเซเบคไคลเอนบางส่วนและคอมไพเลอร์เนลให้เหมาะสมโดยการไม่เลือกในส่วนของฟรีซีสเต็มของระบบที่เป็นตัวเพิ่มความรู้ให้กับเคอร์เนล จะทำให้ตัวเคอร์เนลเองไม่รอบรับการซ่อนตัวของเซเบค และได้แก้ไขส่วนของแฟล็กในเนื้อโปรแกรมให้เหมาะสมกับเคอร์เนลเวอร์ชัน 2.4.x และเมื่อคอมไพเลอร์เนลได้ตามที่แนะนำแล้วนั้น ก็จำเป็นต้องเปลี่ยนแปลงไลบรารี ของระบบให้เป็นของตัวเคอร์เนล 2.4.26 เท่านั้น เนื่องจากว่าภายในเนื้อโปรแกรมของเซเบคไคลเอน ได้เรียกใช้ไลบรารีของเคอร์เนลเวอร์ชันนี้โดยแท้จริงแล้วสามารถเปลี่ยนไลบรารีของคอมไพเลอร์ก็ได้เช่นกัน

สถาปัตยกรรม

ในส่วนของแนวคิดนั้นได้เพิ่มความสามารถของระบบนี้เพื่อทำให้มีความสามารถสูงสุดในส่วนของการ ล่อหลอกผู้บุกรุก เนื่องจากเมื่อก่อนนั้น หากว่าผู้บุกรุกเอง ไม่เข้าไปยังเครื่องกับดัก ระบบนี้พื๊ดเองก็หมดซึ่งประโยชน์ในการป้องกันระบบเครือข่าย แต่ผู้พัฒนาได้เพิ่มความสามารถในการล่อหลอกผู้บุกรุก เพื่อแก้ไขปัญหาความหมดประโยชน์ของฮาร์ดแวร์ที่พื๊ดรุ่นเก่าออกไป โดยการใช้ความสามารถของ ไฟร์วอลล์ และ ระบบตรวจจับผู้บุกรุกให้มีศักยภาพในการทำงานร่วมกัน เนื่องจากเมื่อก่อนนั้นสองโปรแกรมนี้ไม่สามารถเชื่อมต่อและทำงานร่วมกันได้อย่างเต็มที่ แต่ในเวลานี้ผู้พัฒนา ได้ ออกแบบให้สามารถทำงานร่วมกันได้เพิ่มขึ้นไปอีกระดับหนึ่ง โดยการใช้ตัวสื่อสารกลางเป็นตัวแปลงคำสั่งให้เหมาะสม ดังรูปด้านล่าง



รูปที่ 2 ไดอะแกรมการทำงานร่วมกันได้ของไฟร์วอลล์และระบบตรวจจับผู้บุกรุก

จากรูปไดอะแกรมสามารถอธิบายหลักการทำงานของรูปแบบการจำแนกพฤติกรรมผู้บุกรุกได้ดังนี้

1. เมื่อมีชิ้นข้อมูลเข้ามายังตัวฮาร์ดแวร์จะถูกส่งมาให้ยังไฟร์วอลล์เพื่อรับหน้าที่แรกคือ ส่งค่าข้อมูลที่ได้รับเข้ามานั้นไปให้ยังระบบตรวจจับผู้บุกรุก ผ่านทางโมดูล ip_queue
2. ส่งค่าข้อมูลจากที่ได้รับเข้ามาไปยังส่วนของ ip_queue เพื่อให้โปรแกรมทางฝั่งยูสเซอร์โหมด สามารถอ่านไปใช้งานได้
3. ตัวระบบตรวจจับผู้บุกรุกดึงค่าชิ้นข้อมูลที่อยู่ในบ่อน้ำ ip_queue มาเพื่อตรวจสอบพฤติกรรมโดยการทำแพทเทิลแมชชิง กับกฎที่ได้กำหนดไว้
4. ในส่วนของการตรวจสอบชิ้นข้อมูลนั้นมีสองกรณีดังนี้
 - 4.1 เมื่อตรวจพบว่าเป็นชิ้นข้อมูลที่มีความเสี่ยงที่จะเป็นผู้บุกรุก ก็จะแจ้งเตือนออกมา
 - 4.2 ไม่พบว่าเป็นชิ้นข้อมูลนี้เป็นการบุกรุก ก็จะไม่แจ้งเตือนออกมา

5. ในส่วนของการทำงานตัวสื่อสารกลางนั้นมีสองกรณีดังนี้

5.1 เมื่อมีการแจ้งเตือนออกมาจากระบบตรวจจับผู้บุกรุก ตัวสื่อสารกลางหรือที่เรียกว่าเอสทูไอ (s2i) ก็จะแปลงข้อความเพื่อบอกไฟร์วอลล์ว่า ซินข้อมูลที่ได้รับมานั้นต้องส่งไปยังเครื่องกับดัก

5.2 หากไม่มีการแจ้งเตือนตัวสื่อสารกลางจะไม่แจ้งให้ไฟร์วอลล์ส่งซินข้อมูลนั้นไปยังเครื่องกับดัก แต่จะปล่อยให้ไปติดต่อกับเครื่องที่ผู้ติดต่อเข้ามาต้องการ

6. ซินข้อมูลที่ไฟร์วอลล์ได้บอกปลายทางแล้วจะไปยังส่วนที่ถูกกำหนดไว้

การดูแลพฤติกรรม

การดูแลพฤติกรรมของข้อมูลที่เข้ามานั้น อาศัยหลักการส่งซินข้อมูลมายังระบบตรวจจับผู้บุกรุกผ่านทางโมดูลที่ชื่อว่า ip_queue โดยหน้าที่เป็นของ ไฟร์วอลล์จะจัดส่งมาให้ และ หลักการดูแลพฤติกรรมนั้นจะมีสองลักษณะดังนี้

- **Allow all Deny some** เป็นการสนใจว่า ให้ทุกคนที่อยู่ในระบบเครือข่ายนั้นเป็นบุคคลที่เชื่อถือได้ อนุญาต ให้เข้ามาได้ทั้งหมดก่อน แล้วเมื่อมีการกระทำผิดจะค่อยเพิ่มกฎการป้องกัน เพื่อให้การบริการให้แก่บุคคลทั่วไปนั้นทำได้อย่างมีประสิทธิภาพ มักใช้กับระบบงานที่ต้องให้บริการแก่บุคคลภายนอก เช่นบริษัทที่เป็นผู้ดูแลให้บริการเช่าตู้สายเชื่อมต่อระบบอินเทอร์เน็ต ในส่วนนี้จะคิดต่อการติดตั้งให้แก่บริษัท หรือ ระบบเครือข่ายเพื่อธุรกิจ ดังนั้น ผู้ที่อยู่ใน deny lists จะถูกส่งเข้าไปยังกับดักทั้งหมด
- **Deny all Allow some** เป็นการสนใจว่า ให้ทุกคนที่อยู่ในระบบเครือข่ายนั้นเป็นบุคคลที่เชื่อถือไม่ได้ ไม่อนุญาตให้เข้ามาในระบบเครือข่ายได้เลย หากเมื่อต้องการอนุญาตให้บุคคลใดเข้ามาในระบบได้นั้น จะต้องเพิ่มเข้ามาใน allow lists เพื่อให้หมายเลขประจำเครื่องนั้นๆ สามารถเข้ามาได้ในระบบ ซึ่งในรูปแบบเช่นนี้จะเหมาะสมในการทำวิจัยรูปแบบการโจมตีใหม่ๆ เพื่อให้ได้ทราบถึงรูปแบบการโจมตีให้ได้มากที่สุด เนื่องจากว่าการโจมตีแบบใหม่ๆ นั้นจะไม่เข้าข่ายการเข้าขอเชื่อมต่อแบบปกติ ดังนั้น บุคคลที่กระทำพฤติกรรมที่ไม่อยู่ใน allow lists จะถูกส่งเข้าไปยังกับดักทั้งหมด

การจำแนกระหว่างผู้ใช้งานปกติกับผู้บุกรุก

ในการจำแนกระหว่างผู้ใช้งานปกติกับผู้บุกรุกนั้น ขึ้นอยู่กับสองปัจจัยดังนี้

- ในส่วนของความต้องการขององค์กร โดยต้องเลือกใช้ว่าจะให้เป็น Allow All Deny Some หรือว่า Deny All Allow Some ขึ้นอยู่กับความเหมาะสมกับองค์กรนั้นๆ ว่าต้องการให้ระบบอันนี้พื้ทอดเพื่อวัตถุประสงค์ใด หากต้องการใช้เพื่อปกป้องระบบขององค์กรในกรณีที่องค์กรเองไม่ได้เจาะจงให้บริการผู้ใช้งานนอกทั่วๆ ไป ควรที่จะใช้รูปแบบการตั้งกฎเกณฑ์ ให้เป็นแบบ Deny All Allow Some แต่หากว่าต้องการนำระบบอันนี้พื้ทอดไปใช้เพื่อป้องกันระบบเครือข่ายขององค์กรที่ต้องให้บริการแก่บุคคลภายนอก ควรที่จะใช้รูปแบบการตั้งกฎเกณฑ์ ให้เป็นแบบ Allow All Deny Some ในส่วนนี้ต้องขึ้นอยู่กับการต้องการของผู้ที่จะนำระบบอันนี้พื้ทอดไปใช้
- ในส่วนที่สองเป็นการเขียนกฎของตัวระบบตรวจจับผู้บุกรุก

- หากว่าใช้กฎของเดิมก็จะตรวจสอบรูปแบบอย่างละเอียดซึ่งตัวระบบตรวจจับผู้บุกรุกหากใช้กฎเดิมจะตรวจพบแต่เฉพาะ รูปแบบที่เป็นการโจมตีเฉพาะเท่านั้น ดังนั้นผู้ที่ถูกส่งไปยังกับดักนั้น จะต้องกระทำด้วยพฤติกรรมที่ถูกต้องตรงตามรูปแบบการบุกรุก ไม่ผิดเพี้ยน จะมี
 - ข้อดีที่ว่าหากผู้บุกรุกจริงจะเข้าไปยังกับดักแต่หากว่าเป็นผู้ใช้งานทั่วไปก็จะไม่หลงเข้าไปในกับดัก
 - ข้อเสีย หากว่าผู้บุกรุกใช้รูปแบบการโจมตีที่ไม่เหมือนทั้งหมด จะไม่สามารถตรวจจับได้
- หากว่าใช้กฎที่ดัดแปลงจากของเดิม จะช่วยให้ตรวจสอบแนวการโจมตีที่คล้ายคลึงกัน หรือใกล้เคียงกันได้ตามแต่การเขียนกฎว่าตรวจสอบละเอียดเพียงใด
 - ข้อดี หากว่าผู้บุกรุกเปลี่ยนรูปแบบการโจมตีไปแต่ยังเข้าข่ายการโจมตี ก็จะถูกส่งไปยังกับดัก
 - ข้อเสีย หากว่าผู้ใช้งานทั่วไปเกิดพลาดพลั้งกระทำโดยคล้ายคลึงกับการบุกรุกเพียงเล็กน้อยก็จะถูกส่งไปยังกับดักเช่นกัน

ในส่วนของการจำแนกแยกแยะจะพบว่า ไม่ใช่ว่าขึ้นกับการตั้งโครงสร้างของการอนุญาตเท่านั้นแต่ยังจะต้องอาศัยความเชี่ยวชาญในการออกกฎของระบบตรวจจับผู้บุกรุกเองด้วยเช่นกัน ดังนั้นผู้ดูแลระบบเองจำต้องมีความสามารถในการออกแบบกฎให้เหมาะสมกับการใช้งานร่วมกันกับ ความต้องการขององค์กร และระบบอื่นที่พัวพันเองด้วย หากขาดซึ่งความเชี่ยวชาญแล้ว ระบบให้ว่าออกแบบมาดีเพียงใด ก็เป็นเสมือนกับ ของเล่นที่ประกอบไปด้วยช่องโหว่ซะเอง อย่างนี้แล้วคงป้องกันระบบใดๆ ไม่ได้แน่นอน

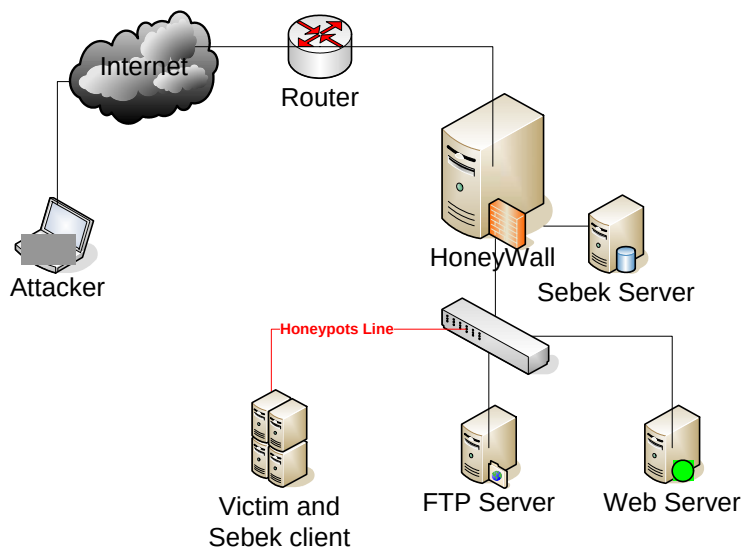
การตรวจสอบกับดัก

- ป้องกันมิให้ผู้บุกรุกที่อยู่ใน cage กระทำการบุกรุกออกมา
- เพื่อปิด cage นั้น ได้ทันทีเมื่อมีความบอบช้ำมากเกินไป

ความสามารถในการควบคุมกับดัก

- กำหนดค่าต่างๆของ cage
- แสดงพอร์ตต่างๆที่เปิดอยู่และสามารถเพิ่มเติมได้
- จัดเก็บค่าเริ่มต้นบางอย่างที่ใช้เทียบเพื่อวัดความอ่อนแอ
- ทำการปิดระบบโดยทำการ pause โปรแกรม virtual machine

รายละเอียดของการพัฒนา

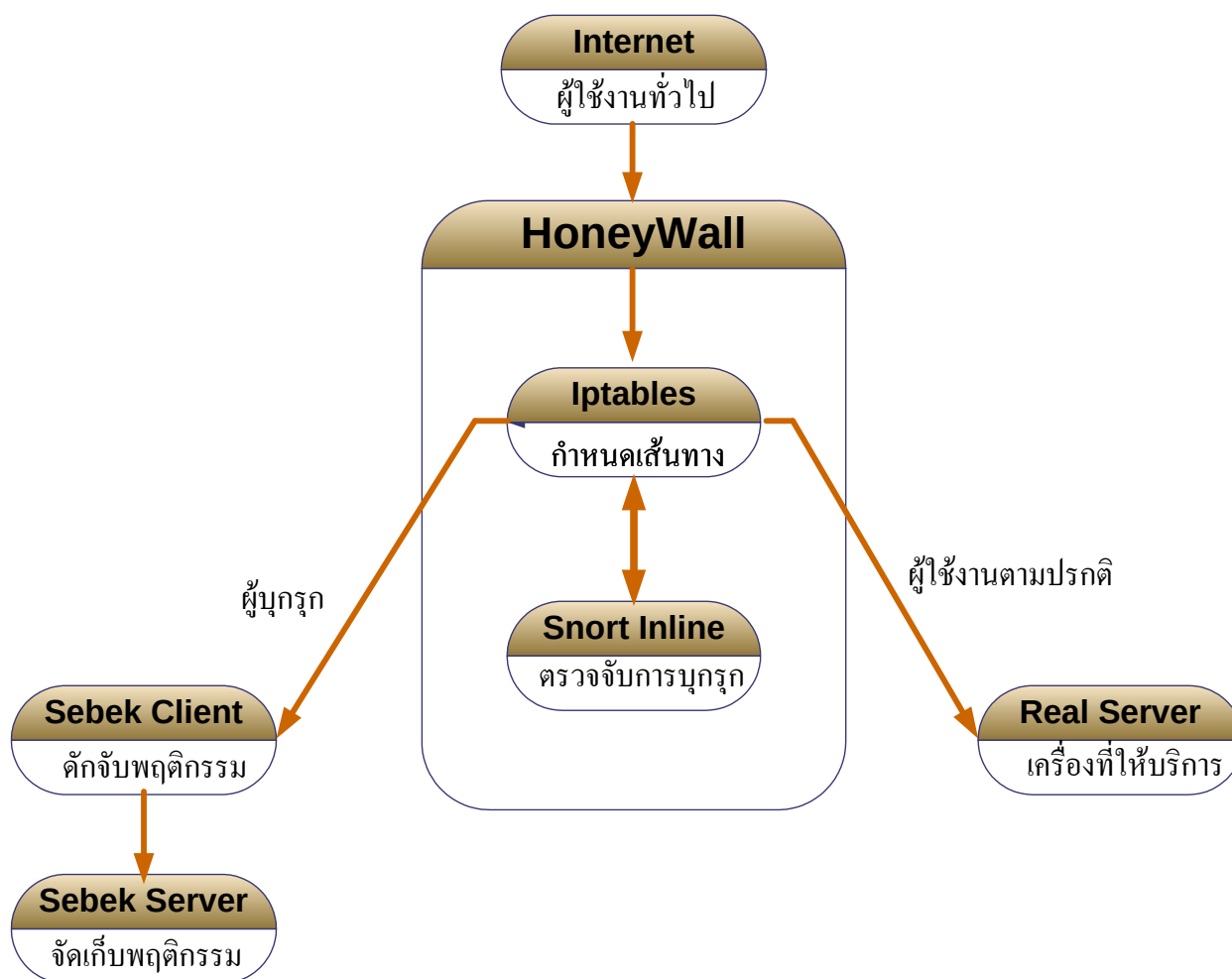


รูปที่ 3 รูปการเชื่อมต่อ Honeypot Program Suite ในการทดลอง

รูปตัวอย่างด้านบนแสดงการจัดวางฮันนีพ็อต โดยฮันนีพ็อตเป็นระบบจำแนกและจัดเส้นทาง การเชื่อมต่อที่เหมาะสม โดยใช้แนวคิดของระบบตรวจจับการบุกรุกทางเครือข่ายและใช้แนวคิดของ Network Address Translation (NAT) ตามลำดับ

โปรแกรมต้นแบบที่สร้างขึ้นนี้เป็นระบบรักษาความปลอดภัยตามแนวคิดของ Honeypot โดยอาศัยหลักการของไฟร์วอลล์และระบบตรวจจับการบุกรุกผ่านเครือข่ายเข้าร่วมจำแนก เพื่อให้ตรวจจับ บันทึกและวิเคราะห์พฤติกรรมของผู้บุกรุกได้งาย ระบบนี้

ล่อหลอกผู้บุกรุกให้เข้าใจผิดว่าเป็นระบบที่อ่อนแอแต่กลับเป็นระบบที่มีการเฝ้าดูพฤติกรรมทุกขณะ เมื่อผู้บุกรุกเข้าสู่ระบบ ระบบจะจัดวิธีทางให้ผู้บุกรุกดำเนินไปตามความเหมาะสม ตลอดช่วงดังกล่าวก็บันทึกเหตุการณ์ ที่ผู้บุกรุกกระทำ และเมื่อผู้บุกรุกออกจากระบบ ทุกอย่างก็จะกลับคืนสู่ภาวะเดิมเสมือนไม่มีการบุกรุกเกิดขึ้น ซึ่งผู้บุกรุกไม่อาจทราบได้เลยว่าตนเข้าไปบุกรุกระบบที่ถูกจัดไว้เฉพาะและเก็บบันทึกหลักฐานเหตุการณ์ต่างๆ เรียบร้อยแล้ว



รูปที่ 4 การเชื่อมต่อระหว่างส่วนต่างๆของโปรแกรมเพื่อทำการจำแนกผู้ใช้งานปกติกับผู้บุกรุก

จากรูป Snort จะตรวจสอบแยกแยะระหว่างผู้บุกรุกกับผู้ใช้งานทั่วไปจากนั้นจะติดต่อไปยัง Iptables เพื่อให้จัดเส้นทางของการใช้งานระบบเครือข่ายอย่างเหมาะสมตามการจำแนกที่ Snort ได้ตรวจสอบมาหากเป็นผู้ใช้งานตามปกติจะส่งไปยัง Real Server และหากเป็นผู้บุกรุกจะส่งไปยังระบบที่ได้จัดเตรียมไว้ซึ่งจะมี Sebek client ซ่อนตัวเพื่อจับเก็บส่งการกระทำของผู้บุกรุกไปยัง Sebek server (Log Server)

content:"|0A 00 00 01 85 04 00 00 80|root|00|";

มีหัวข้อในชั้นข้อมูลดังนี้ ให้ ส่งค่ากลับของระบบไปยังพอยน์เตอร์ที่ได้รับไว้หากว่าเป็น root ดังนี้

XXXX เป็นเซ็กเมนต์

เริ่มที่ออฟเซตหนึ่งร้อย

Segment:Offset	Binary code	Assembly code
XXXX:0100	0A00	OR AL,[BX+SI]
XXXX:0102	0000	ADD [BX+DI], AL
XXXX:0104	8504	TEST AX,[SI]
XXXX:0106	0000	ADD [BX+SI],AL
XXXX:0108	807C726	CMP ว่าเป็น root หรือไม่
XXXX:010C	6F	DB เป็นการ Define byte เพื่อเปรียบเทียบ คำว่า root
XXXX:010E	747C	JZ หากว่าเป็นศูนย์แสดงว่าใช่ root ให้return
XXXX:0111	0000	ADD [BX+DI], AL
XXXX:0113	7CXX	JL จะตรวจ Carry Flag ดังนั้นจึงเป็น loop เสมอเพราะ

Carry Flagตีความถึงว่าน้อยกว่า

classtype:protocol-command-decode; sid:1775; rev:2;)

จะใช้ส่งในรูปแบบคำสั่ง

ในกรณีที่ต้องการสร้างกฎให้มีความยืดหยุ่น

```

alert tcp $EXTERNAL_NET any -> $SQL_SERVERS 3306
(msg:"MYSQL root login attempt";
flow:to_server,established;
|
| content:"|0A 00 00 01 85 04 00 00 80|root|00|";
|
| classtype:protocol-command-decode; sid:1775;
|
)

```

ในส่วนของเส้นประให้นำออกเพื่อตั้งให้กฎเองมีความยืดหยุ่นที่ว่าหากเข้ามาเชื่อมต่อเข้ามายังช่องทางหมายเลข สาม สามศูนย์หก ลักษณะการขอการสถาปนา ก็ให้ถือว่าเป็นการโจมตีจากผู้บุกรุก

ข้อดีข้อเสียของการเปลี่ยนแปลงกฎ

การใช้กฎเดิม

ข้อดี

- ผู้ใช้งานทั่วไปจะไม่หลงเข้ามายังกับดัก เนื่องจากเมื่อผู้บุกรุกเข้ามาตรงตามกฎเท่านั้นถึงจะถือว่าเป็นผู้บุกรุก

ข้อเสีย

- ผู้บุกรุกหากเปลี่ยนรูปแบบการโจมตีที่แตกต่างออกไปบางส่วนจากกฎที่กำหนดก็จะไม่สามารถตรวจพบ จะทำให้ส่งผ่านให้ผู้บุกรุกเข้าไป

การใช้กฎที่แก้ไข

ข้อดี

- ผู้บุกรุกที่เข้ามาในรูปแบบที่เปลี่ยนไปแต่ยังจัดอยู่ในกลุ่มการโจมตีจะสามารถตรวจสอบได้ว่าเป็นผู้บุกรุก

ข้อเสีย

- ผู้ใช้งานทั่วไปอาจจะถูกส่งไปยังกับดักได้ เนื่องจากการกระทำที่ไม่ได้ตั้งใจของผู้ใช้งาน

ข้อจำกัดของการพัฒนา

ในส่วนการทำงานของระบบฮันนีพ็อตที่ผู้พัฒนาได้จัดทำยังไม่สามารถปิดบังการแสดงตัวตนของเครื่องกับดักได้ เนื่องจากว่าหากผู้บุกรุกใช้คำสั่งเพื่อแสดงตัวที่เครื่องกับดักจะทราบทันทีว่าไม่ใช่เครื่องที่ตนเองต้องการเข้าติดต่อ และจะทำให้การไม่แสดงตัวของฮันนีพ็อตสูญเสียไป